

POL-SEC-001 - Security Incident Response Policy

Policy | IT

Document ID	POL-SEC-001	Seller ID	Organization-wide
Department	IT	Classification	INTERNAL
Owner	Admin	Created Date	2026-04-30
Version	3.1	Effective Date	2026-04-30
Related Scenario ID	SC-008	Document Type	Policy

1. Purpose

This policy defines how security incidents are detected, classified, contained, investigated and closed. It covers credential exposure, unauthorised access, suspected data exposure and security-relevant misconfiguration.

Its guiding principle is that containment takes precedence over investigation, and that an exposed credential is treated as compromised regardless of evidence about whether it was used.

2. Scope

Applies to any actual or suspected security event affecting platform systems, seller data, customer data or credentials.

Applies to events detected internally, reported by a seller, or reported by a third party such as a payment processor or logistics provider.

Does not cover availability incidents with no security dimension, which follow the Incident Escalation Procedure.

3. Definitions

Term	Definition
Security incident	Any event affecting confidentiality, integrity or access control
Credential exposure	A credential that has become accessible outside its intended custodians
Containment	Action that stops the exposure from being exploitable
Confirmed compromise	Evidence of unauthorised access or use
Suspected compromise	Exposure established, use not established
Blast radius	The set of systems, records and accounts potentially affected

4. Classification

R-1. Every security incident is classified at least **RESTRICTED** at creation, regardless of assessed severity. Reclassification downward requires Platform Administrator approval and a recorded rationale.

R-2. Every security incident is **SEV-1 by default**, regardless of confirmed impact.

R-3. Severity may be reduced after containment where the blast radius is established and no compromise is found. Reduction is recorded with reasoning.

R-4. A confirmed compromise involving customer data, payment data or credentials with write access to seller commercial data is escalated to the Platform Administrator and Business immediately.

5. Response Procedure

Step 1 - Report

R-5. Any identity who suspects a security incident must report it to IT immediately. Reporting must not wait for confirmation.

R-6. A person who reports promptly is treated as having acted correctly, regardless of how the exposure occurred. The response addresses the cause, not the reporter.

Step 2 - Contain

R-7. The Platform Administrator may authorise immediate containment, including credential rotation, **without seller consent and without waiting for seller readiness**.

R-8. Containment must not be delayed to establish whether the exposure was exploited. Exploitation is established, if at all, during investigation.

R-9. Where containment interrupts a seller's service, the interruption is accepted where the alternative risk is larger. Fees and service credits do not apply to a containment action initiated under this policy.

In April 2026, rotating a compromised credential broke a seller's feeds for 80 minutes. The alternative was leaving an unknown party holding a valid credential with write access to 142,000 listings. Rotation was authorised within 35 minutes of the exposure being located.

Step 3 - Establish Blast Radius

R-10. Determine: which credential or access path, which systems, which accounts, and which time window.

R-11. Review authentication and access logs for the period before exposure was detected, not only after.

R-12. A log review finding no evidence of use is recorded as **absence of evidence**, never as evidence that access did not occur.

Step 4 - Investigate

R-13. Investigate how the exposure occurred, not only what was exposed. The mechanism determines the preventive action.

R-14. Investigate whether the exposure was systematic. A credential in a shared script usually indicates a practice rather than a single lapse.

R-15. Review whether a similar exposure exists elsewhere. Where one credential is found, sweep for others before closing.

Step 5 - Remediate

R-16. Rotate every exposed credential. Treat all as compromised.

R-17. Where a credential was shared across environments, issue separate credentials.

R-18. Apply the preventive controls identified, with owners and dates.

R-19. Preserve evidence until the incident is closed and any review is complete.

Step 6 - Notify

R-20. The affected seller is told what happened to the extent it affects them, including any action required, without disclosing the classification framework or the controls bypassed.

R-21. Customer notification is assessed by the Platform Administrator and Business together, where customer data is potentially involved. Notification is made where required by law or where notification reduces customer harm.

R-22. Where a third party is involved, for example a provider whose API was compromised, coordination is led by IT.

Step 7 - Close

R-23. An incident may be closed where containment is complete, the blast radius is established, preventive actions have owners and dates, and the affected seller has been notified of the outcome.

R-24. A security incident is not closed at containment. Log review and preventive action completion are required.

6. Responsibilities

Role	Responsibility
Platform Administrator (IT)	Incident ownership, containment authorisation, notification decisions
Engineering	Cause investigation, corrective implementation, secret scanning
Support	Seller coordination and communication
Business	Commercial consequences, customer notification input
All identities	Immediate reporting

7. Exceptions

E-1. Containment may be deferred only where the containment action itself would cause greater harm than the exposure, and only with Platform Administrator approval and a recorded rationale.

E-2. Log review may be limited in scope where log retention does not cover the full window. The limitation is recorded as a finding.

E-3. No exception may waive R-2 (SEV-1 default), R-8 (no delay for exploitation assessment) or R-16 (rotate every exposed credential).

8. Escalation

Situation	Escalate to	Timeframe
Any credential exposure	Platform Administrator	Immediately
Confirmed compromise	Platform Administrator and Business	Immediately
Exposure involving customer or payment data	Platform Administrator and Business	Immediately
Containment requires service interruption	Seller notified by Support	Before or during action
Similar exposure found during sweep	Platform Administrator	Immediately
Log retention insufficient for the window	IT	Within 1 working day

9. Enforcement

Secret scanning in the CI pipeline fails any build containing a credential. A full repository sweep is performed quarterly, including internal tooling and documentation.

Credential rotation is automated; any credential exceeding its maximum age raises an alert.

Incident classification is enforced at record creation; a security incident created below RESTRICTED is rejected.

Containment authority is held by the Platform Administrator and is not delegated below that role.

10. Review History

Version	Date	Change	Owner
1.0	2022-10-03	Initial security incident response policy	IT
2.0	2024-08-27	Containment precedence over investigation formalised	IT
3.0	2026-04-22	SEV-1 default; rotation of every exposed credential	Admin
3.1	2026-04-30	Automated rotation requirement; absence of evidence wording	Admin

Next scheduled review: April 2027.